BẢO MẬT THÔNG TIN TRONG THƯƠNG MẠI ĐIỆN TỬ

- Mã học phần: **25C4INF50902801**
- Lớp: **LT29.4EE01(39); LT30.1EE01(7); VB28.1EE01(6) V121TP4EC1(2); V123TP2EE1(2); V123TP4EE1(2) VB25.1EE01(2); LT27.2EE01(1); V121TP1EC1(1) V121TP3EC1(1); V122TP3EC1(1); V122TP4EC1(1) V123TP1EE1(1); V124TP1EE1(1); V124TP2EE1(1)**
- Thời gian: 02/10/2025 - 25/11/2025
- Số lượng: 68 Học viên
- Số tín chỉ: 3.00

TS. NGUYỄN QUỐC HÙNG

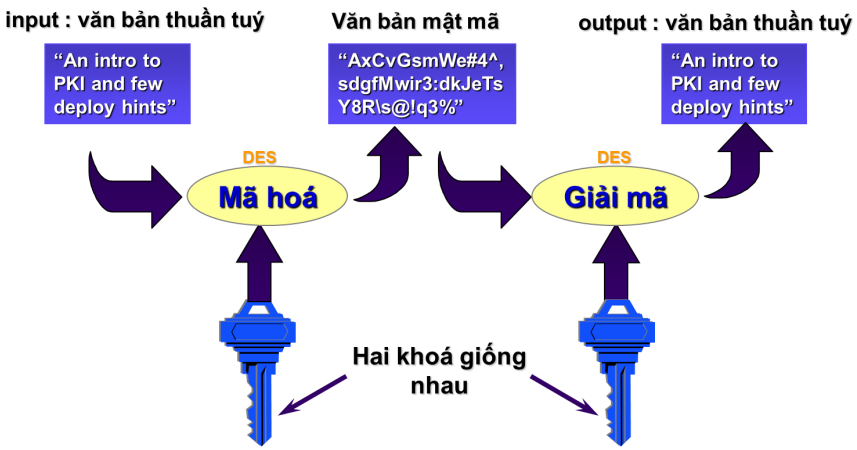
- Mobile: 0912 251 253
- Email: hungngq@ueh.edu.vn
- Website: https://bit.ueh.edu.vn/nqhung/

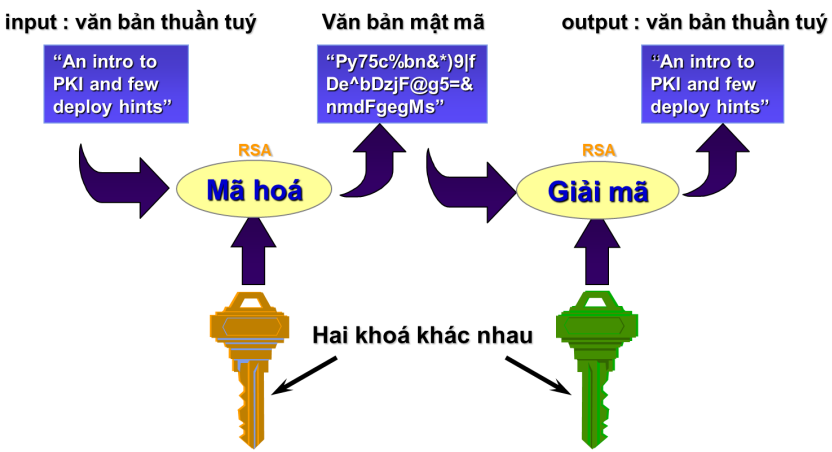
TỔNG QUAN VỀ MÃ HÓA HIỆN ĐẠI

Thời gian: 18g30 - 21g10, Hình thức: Trực tiếp – Giảng đường: B2- 508

NỘI DUNG

1. Mã hóa đối xứng
2. Mã hóa bất đối xứng





Vấn Đề đặt ra: Tại sao chúng ta cần mã hóa?

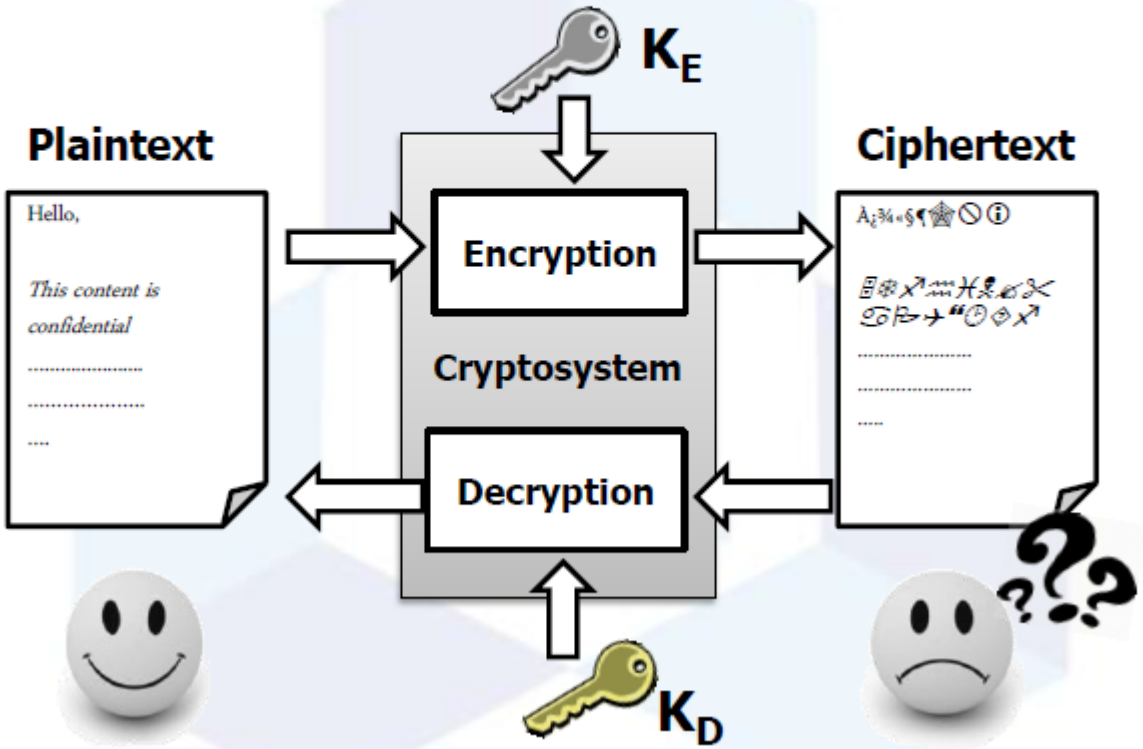
- Mã hóa là một phương pháp hỗ trợ rất tốt trong việc chống lại những truy cập bất hợp pháp tới dữ liệu được truyền đi qua các kênh truyền thông.
- Mã hoá sẽ khiến cho nội dung thông tin được truyền đi dưới dạng mờ và không thể đọc được đối với bất kỳ ai cố tình muốn lấy thông tin đó.

Mã hóa hiện đại (modern cryptography)

- ***Hệ thống mã hóa đối xứng (Symmetric cryptosystem)*** là hệ thống mã hóa sử dụng một khóa bí mật chia sẻ (shared-secret-key) cho cả hai quá trình mã hóa và giải mã.
- ***Hệ thống mã hóa bất đối xứng (Asymmetric cryptosystem)*** là hệ thống mã hóa sử dụng một khóa công khai (public key) và một khóa bí mật (private key) cho quá trình mã hóa và giải mã.
- Hệ thống mã hóa bất đối xứng còn được gọi là hệ thống mã hóa khóa công khai (public-key cryptosystem)

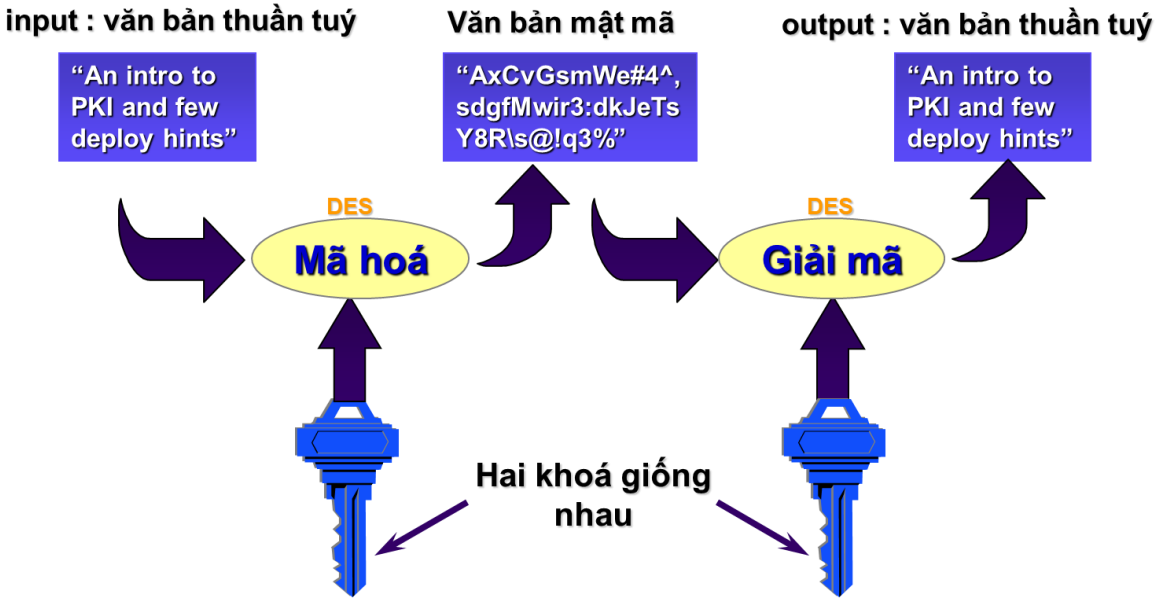
Mã hóa hiện đại (modern cryptography)

- Mã hóa đối xứng: $K_E = K_D$
- Mã hóa bất đối xứng: $K_E \neq K_D$



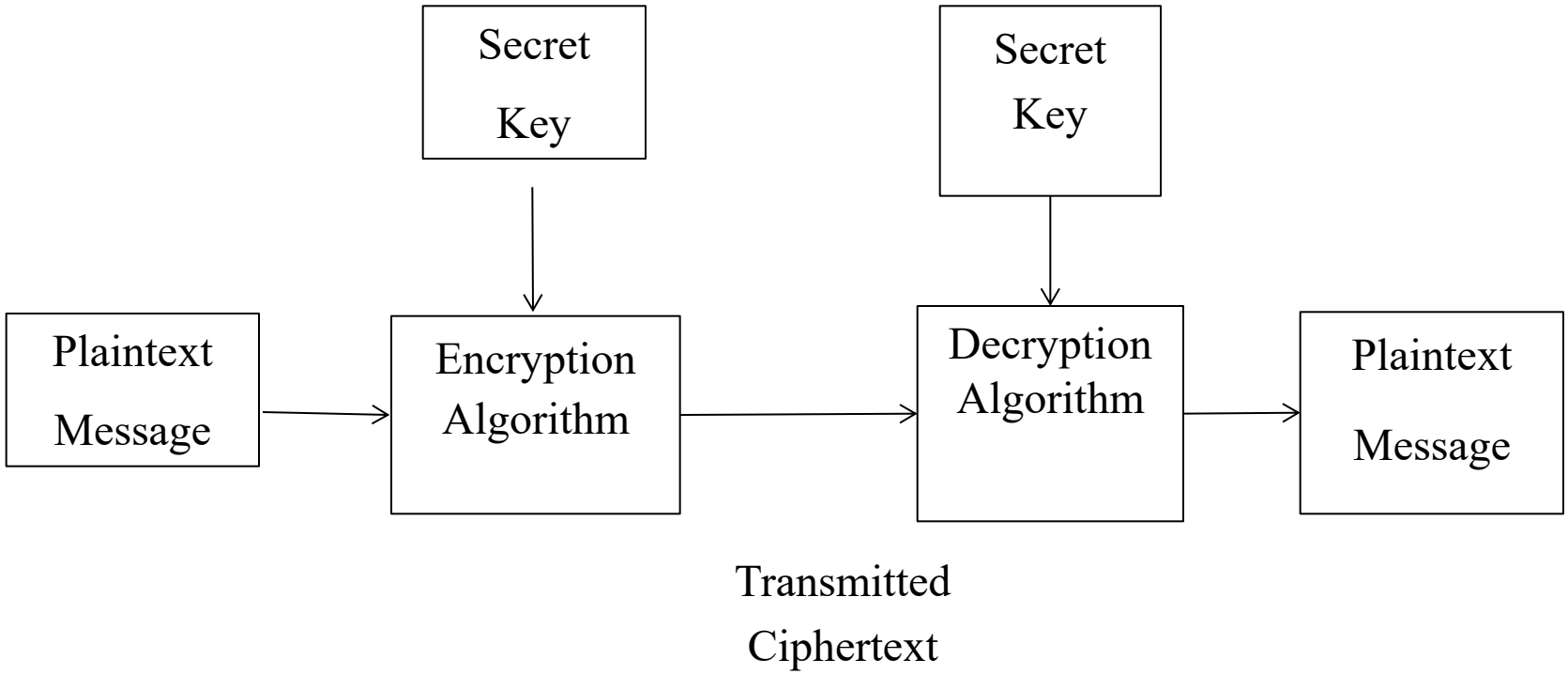
Mã hóa hiện đại (modern cryptography)

- **Mã hóa hiện đại (modern cryptography):** mã hóa đối xứng (symmetric cipher, secret key cryptography – 1 khóa), bất đối xứng (asymmetric cipher, public key cryptography – 2 khóa), hàm băm (hash functions – không có khóa).



Mã hóa đối xứng (symmetric cipher)

Sơ đồ mã hóa đối xứng



Một số thuật toán mã hóa đối xứng: DES, AES, Blowfish, RC5, RC6 …

Phân loại

- **Mã dòng (stream cipher)** là một kỹ thuật mã hóa mà mã hóa một dòng dữ liệu số một bit hoặc một byte tại một thời điểm.

- **Mã khối (block cipher)** là một cơ chế mã hóa/giải mã mà trong đó một khối của bản rõ được xử lý như một tổng thể và dùng để tạo ra khối bản mã có độ dài bằng nhau. Thông thường kích cỡ khối là 64 hoặc 128 bit được sử dụng.

Giới thiệu một số thuật toán

- Mã Feistel (Feistel Cipher)
- Mã DES (Data Encryption Standard)
- Mã Triple DES
- Mã AES (Advanced Encryption Standard)
- RC 4, RC 5, RC 6 (Rivest Cipher 4,5,6)
- Skipjack
- Blowfish
- CAST-128

Feistel Cipher

- **Số dòng (Number of rounds)**: Bản chất thuật toán mã Feistel là một dòng duy nhất là đã cung cấp đầy đủ tính an toàn nhưng nếu số vòng càng tăng thì tính an toàn càng cao. (thông thường 16 vòng).
- **Thuật toán phát sinh khóa con (Subkey generation algorithm)**: Thuật toán càng phức tạp thì sẽ khó khăn hơn trong việc thám mã.
- **Hàm vòng F (Round function F)**: Càng phức tạp thì đề kháng càng cao đối với thám mã.

Feistel Cipher

Ưu điểm:

- Quá trình mã hóa và giải mã trùng nhau, chỉ khác nhau ở thứ tự khóa con, điều này sẽ tiết kiệm được nữa tài nguyên khi thực hiện thuật toán trên phần cứng.
- Hàm F có thể chọn với độ khó bất kỳ, vì không phải tìm hàm nghịch.

Feistel Cipher

Nhược điểm:

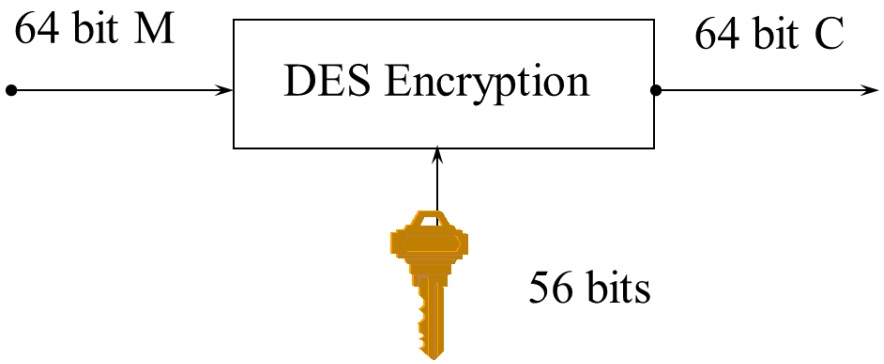
- Vì mỗi vòng mã chỉ thực hiện biến đổi nữa khối dữ liệu, nên cần số vòng mã hóa lớn để đảm bảo độ an toàn của hệ mật, điều này làm giảm đáng kể tốc độ mã.
- Ngoài ra xây dựng trên cơ sở mạng Feistel tồn tại lớp khóa tương đương, nên làm không gian khóa giảm đi một nữa.

Mã DES
(Data Encryption Standard)

- DES được công nhận vào năm 1977 bởi Viện nghiên cứu quốc gia về chuẩn của Mỹ (NIST –National Institut of Standards and Technology), chuẩn hóa 1979.
- Là mã thuộc hệ mã Feistel gồm 16 vòng, ngoài ra DES có thêm một hoán vị khởi tạo trước khi vào vòng 1 và một hoán vị khởi tạo sau vòng 16
- Kích thước của khối là 64 bít.
- Ví dụ bản tin "*meetmeafterthetogaparty*" biểu diễn theo mã ASCII thì mã DES sẽ mã hóa làm 3 lần, mỗi lần 8 chữ cái (64 bít): *meetmeaf - tertheto - gaparty.*

Đặc điểm của thuật toán DES

- Khóa dùng trong DES có độ dài toàn bộ là 64 bit. Tuy nhiên chỉ có 56 bit thực sự được sử dụng; 8 bit còn lại chỉ dùng cho việc kiểm tra.
- Mỗi vòng của DES dùng khóa con có kích thước 48 bít được trích ra từ khóa chính.
- Des xuất ra bãn mã 64 bit.
- Mã hoá và giải mã được sử dụng cùng một khoá.
- DES được thiết kế để chạy trên phần cứng.



Độ an toàn của DES

- ***Tấn công vét cạn khóa (Brute Force Attack)***
  - Khóa của DES: **56 bít** nên để tiến hành vét cạn khóa cần kiểm tra 2^{56} khóa khác nhau.→ rất lớn
  - 1998, tổ chức Electronic Frontier Foundation (EFF) thông báo đã xây dựng được một thiết bị phá mã DES gồm nhiều máy tính chạy song song, trị giá khoảng 250.000$. Thời gian thử khóa là 3 ngày.
  - Hiện nay mã DES vẫn còn được sử dụng trong thương mại, tuy nhiên người ta đã bắt đầu áp dụng những phương pháp mã hóa khác có chiều dài khóa lớn hơn (128 bít hay 256 bít) như TripleDES hoặc AES.

Độ an toàn của DES

- ***Phá mã DES theo phương pháp vi sai*** (differential cryptanalysis):
  - Năm 1990 Biham và Shamir đã giới thiệu phương pháp phá mã vi sai. Phương pháp vi sai tìm khóa ít tốn thời gian hơn brute-force.
  - Tuy nhiên phương pháp phá mã này lại đòi hỏi phải có 247 cặp bản rõ - bản mã được lựa chọn (chosen-plaintext). Vì vậy phương pháp này là bất khả thi dù rằng số lần thử có thể ít hơn phương pháp brute-force.

Độ an toàn của DES

- ***Phá mã DES theo phương pháp thử tuyến tính*** (linear cryptanalysis)
  - Năm 1997 Matsui đưa ra phương pháp phá mã tuyến tính. Trong phương pháp này, cần phải biết trước 243 cặp bản rõ-bản mã (known-plaintext).
  - Tuy nhiên 243 cũng là một con số lớn nên phá mã tuyến tính cũng không phải là một phương pháp khả thi.

Mã Triple DES

- Một trong những cách để khắc phục yếu điểm kích thước khóa ngắn của mã hóa DES là sử dụng mã hóa DES nhiều lần với các khóa khác nhau cho cùng một bản tin. Đơn giản nhất là dùng DES hai lần với hai khóa khác nhau, cách thức này được gọi là Double DES

$$C=E(E(P, K_1),K_2)$$

- Điều này giống như là Double DES dùng một khóa có kích thước là 112 byte, chỉ có một hạn chế là tốc độ chậm hơn DES vì phải dùng DES hai lần.
- Tuy nhiên người ta đã tìm một phương pháp tấn công Double DES có tên gọi là gặp-nhau-ở-giữa (meet-in-the middle). Đây là một phương pháp tấn công chosen-plaintext.

Mã Triple DES

- Nếu dùng DES ba lần với ba khóa khác nhau, cách thức này được gọi là Triple DES:

$$C=E(E(E(P, K_1),K_2),K_3)$$

- Chiều dài khóa là 168 bít sẽ gây phức tạp hơn nhiều cho việc phá mã bằng phương pháp tấn công gặp-nhau-ở-giữa.
- Trong thực tế người ta chỉ dùng Triple DES với hai khóa *K*1, *K*2 mà vẫn đảm bảo độ an toàn cần thiết.

$$C=E(E(E(P, K_1),K_2),K_1)$$

Mã AES (Advanced Encryption Standard)

- Tiêu chuẩn mã hóa tiên tiến (Advanced Encryption Standard - AES) được giới thiệu vào năm 2001 bởi NIST với mục đích thay thế DES có nhiều hạn chế, và được sử dụng rộng rãi trong các ứng dụng hiện nay, thuật toán được thiết kế bởi Joan Daemen và Vincent Rijmen với tên gọi ban đầu là Rijndael.
- Khóa có kích thước 256 bít là ***"an toàn mãi mãi"*** bất kể những tiến bộ trong ngành kỹ thuật máy tính.
- AES là thuật toán mã hóa đối xứng dạng khối 128-bit

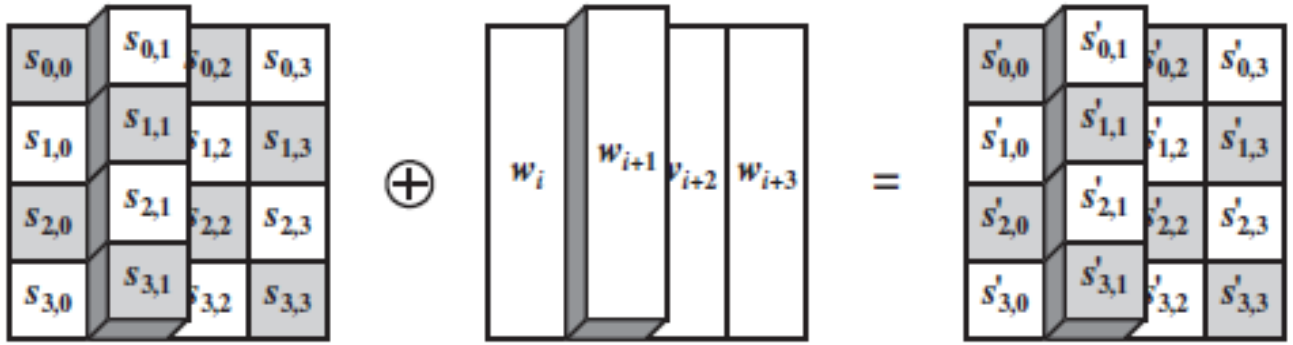
Mã AES (Advanced Encryption Standard)

- Như DES, mã AES là mã khối, nhiều vòng, nhưng mã AES không phải là một mã Feistel. Thuật toán AES khá phức tạp.
- Đặc điểm chính của AES:
  - Cho phép lựa chọn kích thước khối mã hóa là 128, 192 hay 256 bít.
  - Cho phép lựa chọn kích thước của khóa một cách độc lập với kích thước khối: là 128, 192 hay 256 bít.
  - Số lượng vòng có thể thay đổi từ 10 đến 14 vòng tùy thuộc vào kích thước khóa.

Mã AES (Advanced Encryption Standard)

- Quá trình mã hóa bao gồm 4 bước:

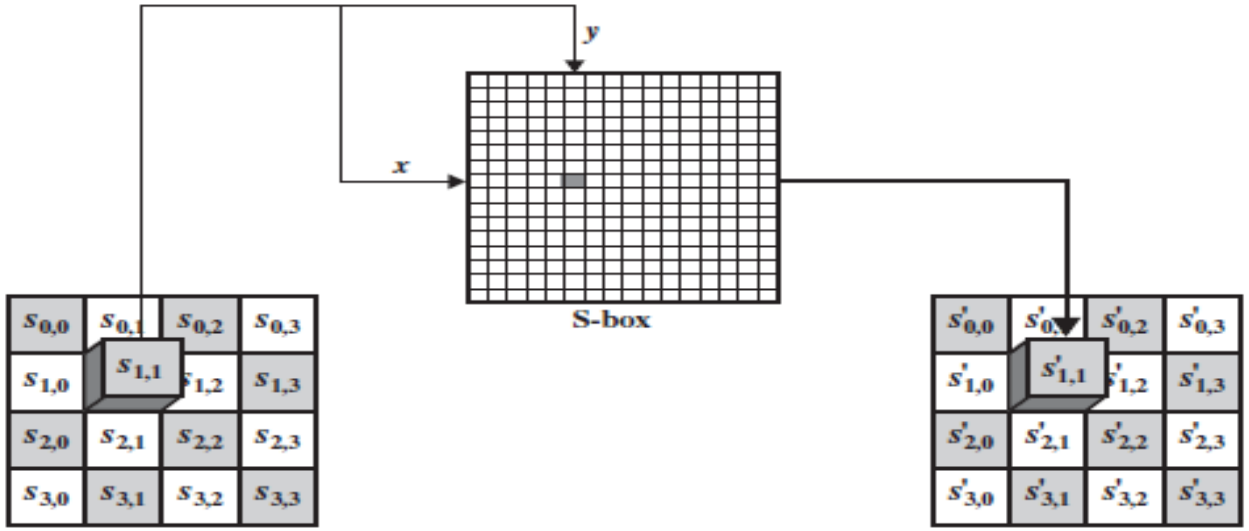
B1: AddRoundKey - mỗi byte của khối được kết hợp với khóa con, các khóa con này được tạo ra từ quá trình tạo khóa con Rijndael.



Add round key transformation

Mã AES (Advanced Encryption Standard)

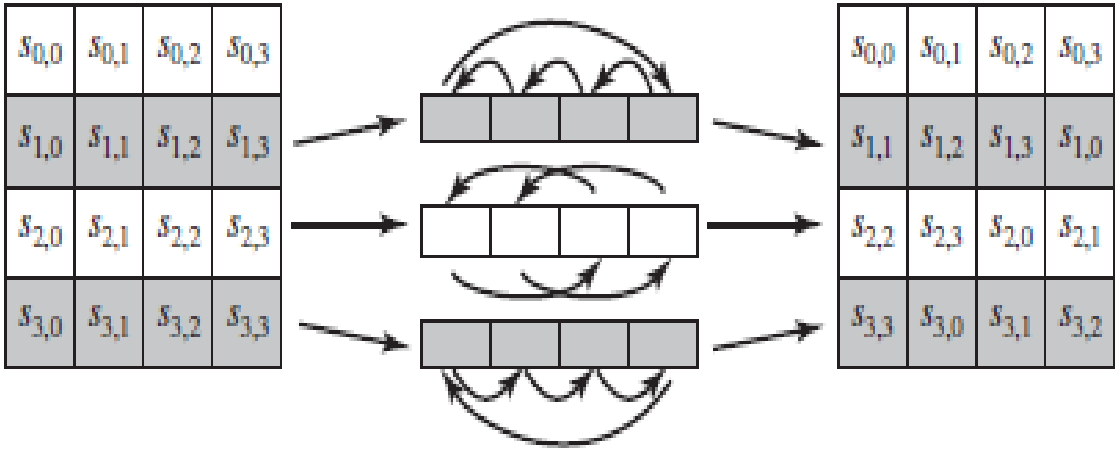
- B2: SubBytes - đây là quá trình thay thế trong đó mỗi byte sẽ được thay thế bằng một byte khác theo bảng tra.



Substitute byte transformation

Mã AES (Advanced Encryption Standard)

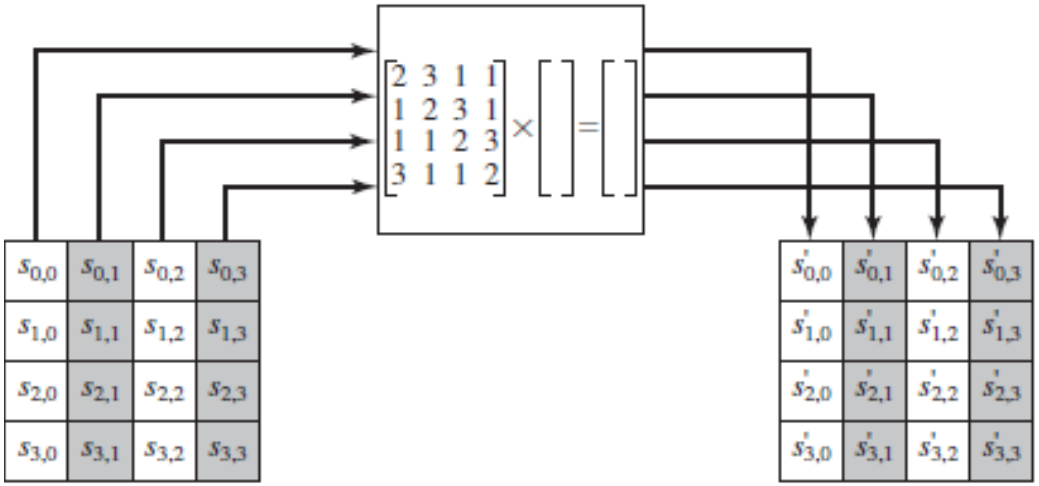
- B3: ShiftRows - đổi chỗ, các hàng trong khối được dịch vòng.



Shift row transformation

Mã AES (Advanced Encryption Standard)

- B4: MixColumns - quá trình trộn làm việc theo các cột trong khối theo một chuyển đổi tuyến tính.
- Tại chu trình cuối thì MixColumns được thay thế bằng AddRoundKey



Mix column transformation

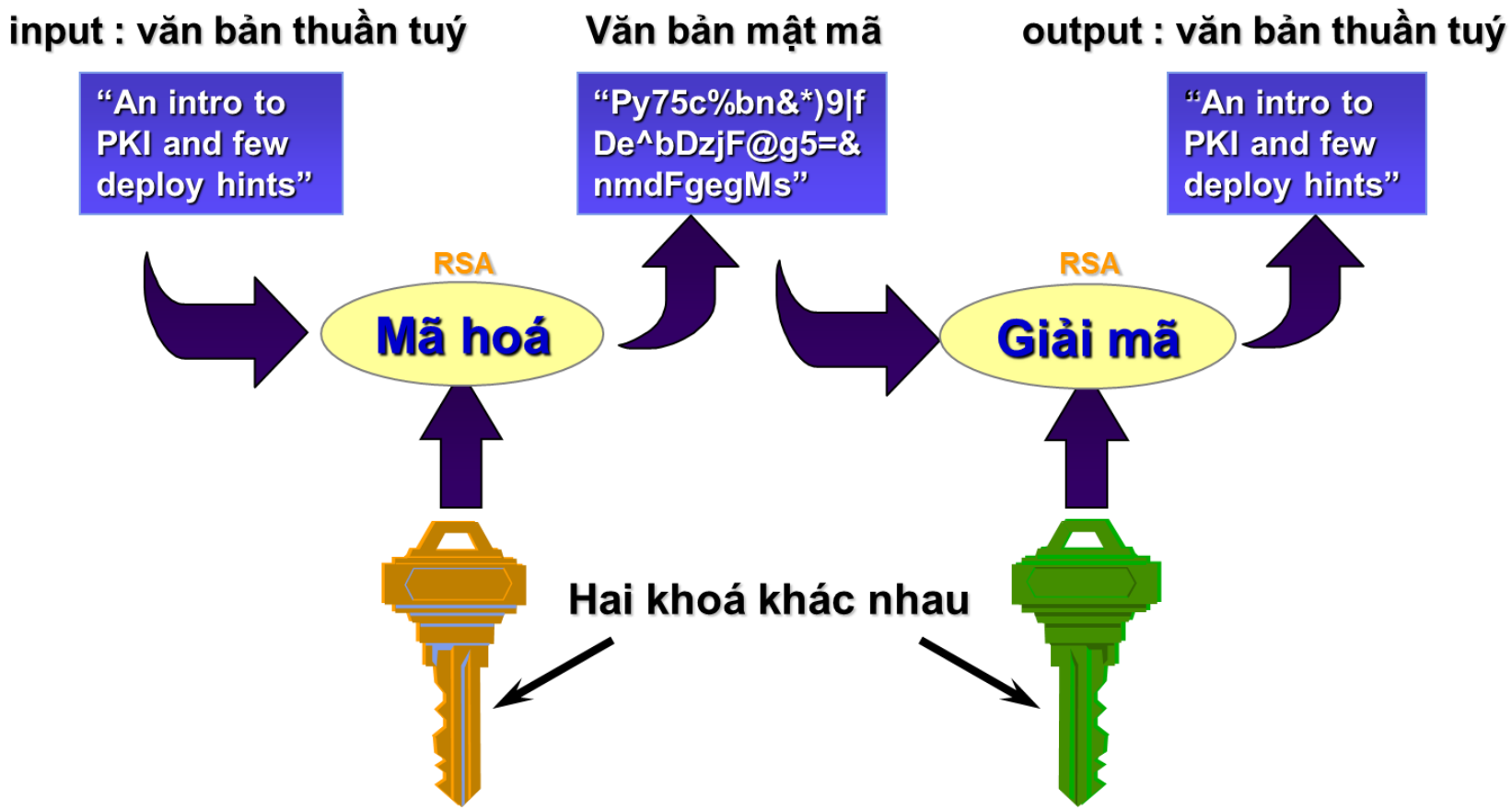
Mã AES (Advanced Encryption Standard)

- Độ an toàn của AES làm cho AES được sử dụng ngày càng nhiều và trong tương lai sẽ chiếm vai trò của DES và Triple DES.

Ưu và nhược điểm của mã hóa đối xứng

- Ưu điểm: độ an toàn cao (phụ thuộc vào thuật toán và khóa), quá trình mã hóa và giải mã nhanh do đó mã hóa đối xứng được sử dụng phổ biến trong việc truyền dữ liệu.

Mã hóa bất đối xứng (Asymmetric cipher)



Đặt vấn đề

Khuyết điểm của mã hóa đối xứng:

- Vấn đề trao đổi khóa giữa người gửi và người nhận: Cần phải có một kênh an toàn để trao đổi khóa sao cho khóa phải được giữ bí mật chỉ có người gửi và người nhận biết. Điều này tỏ ra không hợp lý khi mà ngày nay, khối lượng thông tin luân chuyển trên khắp thế giới là rất lớn. Việc thiết lập một kênh an toàn như vậy sẽ tốn kém về mặt chi phí và chậm trễ về mặt thời gian.
- Tính bí mật của khóa: không có cơ sở quy trách nhiệm nếu khóa bị tiết lộ.

Ý tưởng

- Vào năm 1976 Whitfield Diffie và Martin Hellman đã tìm ra một phương pháp mã hóa khác mà có thể giải quyết được hai vấn đề trên, đó là mã hóa khóa công khai (public key cryptography) hay còn gọi là mã hóa bất đối xứng (asymetric cryptography).
- Whitfield Diffie và Martin Hellman đưa ra 2 phương án sau:

Ý tưởng

- Phương án 1: người nhận (Bob) giữ bí mật khóa *K*2, còn khóa *K*1 thì công khai cho tất cả mọi người biết.
- Alice muốn gởi dữ liệu cho Bob thì dùng khóa *K*1 để mã hóa. Bob dùng *K*2 để giải mã.
- Ở đây Trudy cũng biết khóa *K*1, tuy nhiên không thể dùng chính *K*1 để giải mã mà phải dùng *K*2. Do đó chỉ có duy nhất Bob mới có thể giải mã được.
- Điều này bảo đảm *tính bảo mật* của quá trình truyền dữ liệu.
- Ưu điểm của phương án này là không cần phải truyền khóa *K*1 trên kênh an toàn.

Ý tưởng

- *Phương án 2*: người gửi (Alice) giữ bí mật khóa *K*1, còn khóa *K*2 thì công khai cho tất cả mọi người biết. Alice muốn gởi dữ liệu cho Bob thì dùng khóa *K*1 để mã hóa. Bob dùng *K*2 để giải mã.
- Ở đây Trudy cũng biết khóa *K*2 nên Trudy cũng có thể giải mã được. Do đó phương án này *không đảm bảo tính bảo mật*.
- Tuy nhiên lại có tính chất quan trọng là *đảm bảo tính chứng thực và tính không từ chối*. Vì chỉ có duy nhất Alice biết được khóa *K*1, nên nếu Bob dùng *K*2 để giải mã ra bản tin, thì điều đó có nghĩa là Alice là người gửi bản mã. Nếu Trudy cũng có khóa *K*1 để gửi bản mã thì Alice sẽ bị quy trách nhiệm làm lộ khóa *K*1.
- Trong phương án này cũng không cần phải truyền *K*2 trên kênh an toàn→Mã bất đối xứng kết hợp 2 phương án trên

Mã hóa công khai (Public-Key Cryptosystems)

- Mã bất đối xứng là một dạng của hệ thống mật mã mà trong đó mã hóa (encryption) và giải mã (decryption) được thực hiện bằng cách dùng hai khóa (Key) khác nhau
- Một là khóa công khai (Public key) và một là khóa bí mật (Private key).
- Nó cũng được gọi tên là

MÃ HÓA KHÓA CÔNG KHAI

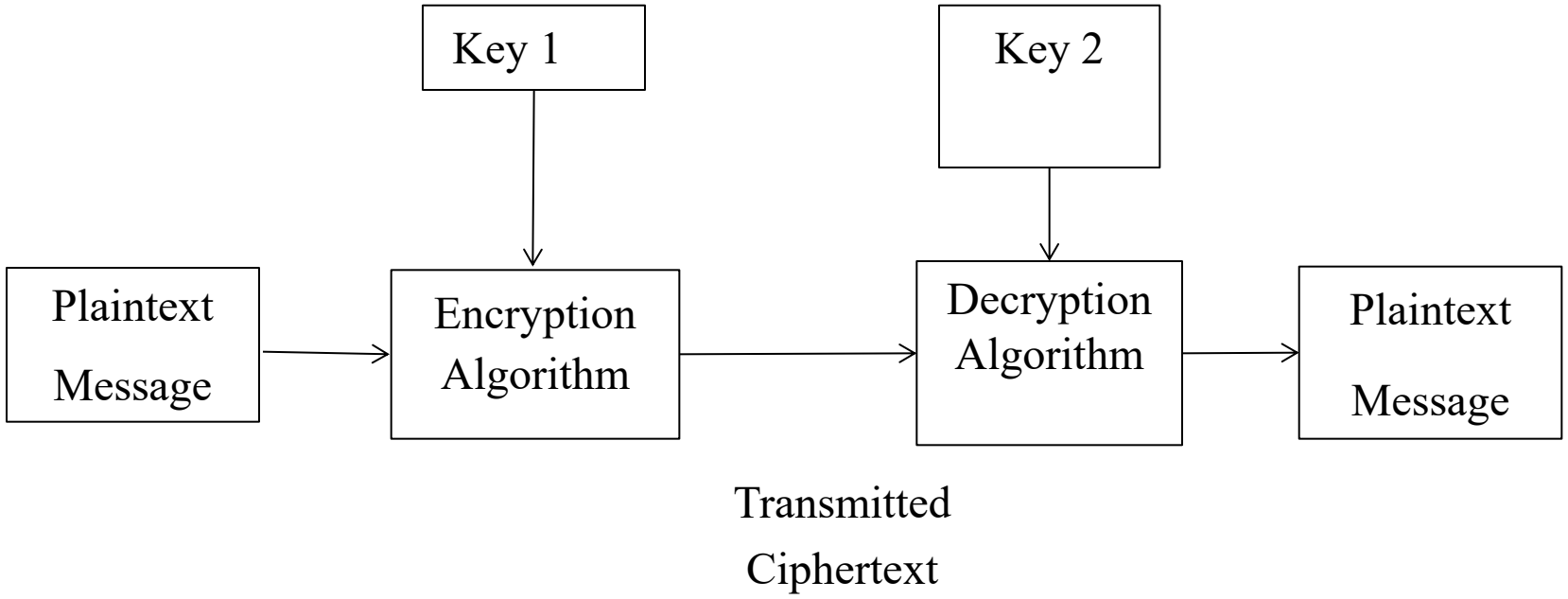
(Public-key Encryption)

Có hai mode làm việc :

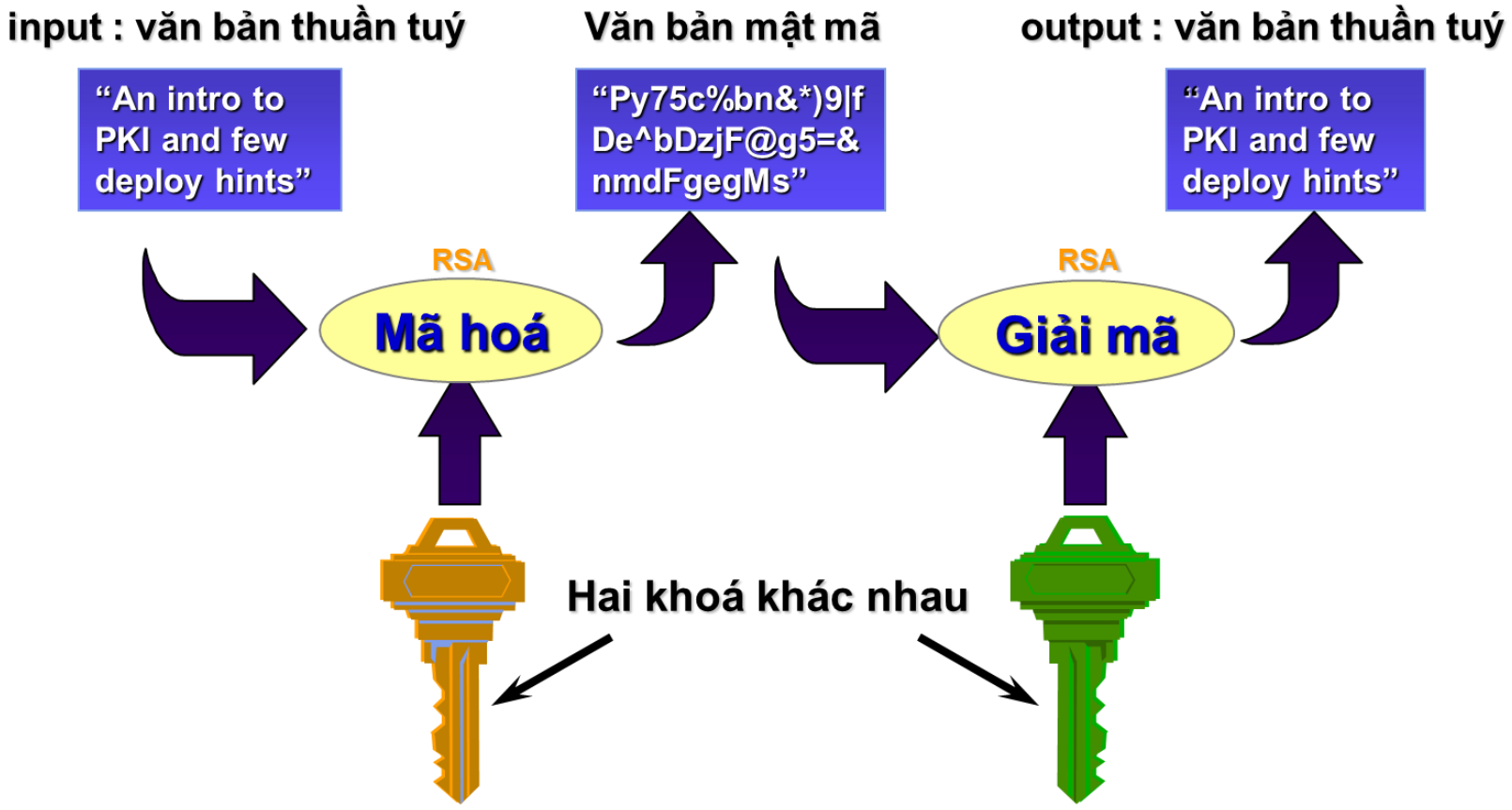
- Bảo mật : Mã bằng public key → giải mã bằng private key
- Xác thực : Mã bằng private key →giải mã bằng public key

Mã hoá bất đối xứng (asymmetric cipher model)

Sơ đồ mã hóa bất đối xứng



Mã hoá bất đối xứng



Mã hóa công khai (Public-Key Cryptosystems)

- Mã bất đối xứng có thể dùng để bảo mật (Confidentiality), chứng thực (Authentication), hoặc cả hai.
- Hiện nay, mã hóa khóa công khai được ứng dụng rộng rãi trong nhiều lĩnh vực, trong đó bao gồm: trao đổi, phân phối khóa, chữ ký số, bảo mật dữ liệu.
- Một số thuật toán mã hóa bất đối xứng: Diffie-Hellman, El-Gamal, RSA, ECC …

Mã hóa công khai (Public-Key Cryptosystems)

- Mã hóa khóa công khai được dùng rộng rãi nhất là mã RSA.
- Độ khó của việc tấn công được dựa vào độ khó của việc tìm thừa số nguyên tố (Prime factors) của một số composite number (hợp số).

Mã hóa công khai (Public-Key Cryptosystems)

- ***Vấn đề phân phối khóa***:
  - Khó đảm bảo chia sẻ mà không làm lộ khóa bí mật
  - Trung tâm phân phối khóa có thể bị tấn công.

- ***Không thích hợp cho chữ ký số***:
  - Bên nhận có thể làm giả thông điệp và nói rằng nhận từ bên gửi.

Mã hóa khóa công khai Public-Key Cryptosystems

- **Mã hóa khóa công khai (*Public-Key Cryptosystems*)**
- Phát minh bởi Whitfield Diffie & Martin Hellman - Stanford Unit, vào năm 1976
- Mục tiêu là khắc phục điểm yếu của mã hóa đối xứng
- Một số ứng dụng cụ thể: SSL, VPN, SSH.
- Phương pháp: ***dùng hai khóa khác nhau cho quá trình mã hóa và giải mã***

$$C = E(P, K_1) \text{ và } P = D(C, K_2)$$

Mã hóa công khai (Public-Key Cryptosystems)

- Tên gọi:
  - **Mã hóa hóa công khai** (***Public-key Cryptosystems***)
  - **Mã hóa hai khóa** (***two-key Cryptosystems***)
  - **Mã hóa bất đối xứng** (***asymmetric Cryptosystems***)
- Hai khóa:
  - Một khóa **public-key**, có thể biết bất cứ ai, và có thể được dùng để mã hóa thông điệp.
  - Khóa **private-key**, chỉ được biết bởi người nhận, dùng để giải mã thông điệp
- Bất đối xứng là bởi vì:
  - Người mã hóa thông điệp không thể giải mã thông điệp do chính mình mã hóa
  - Người thẩm tra chữ ký không thể tạo ra chữ ký

Giải thuật Mã hóa công khai (Public-Key Cryptosystems)

Giải thuật khóa công khai gồm 6 thành phần:

- **Đầu vào của giải thuật:** Bản rõ (thông điệp có thể đọc)
- **Giải thuật mật hóa**
- **Khóa công khai và bí mật:** một cặp khóa được chọn sao cho 1 khóa dùng để mã hóa và 1 khóa dùng để giải mã.
- **Bản mã:** thông điệp đầu ra ở dạng không đọc được, phụ thuộc vào bản rõ và khóa. Nghĩa là với cùng một thông điệp, 2 khóa khác nhau sinh ra 2 bảng mã khác nhau
- **Giải thuật giải mã**

Đặc điểm Public-Key Cryptosystems

- Không thể tính toán để tìm khóa giải mã (decryption key) khi chỉ biết thuật toán và khóa mã hóa (encryption key)

- Một trong hai khóa có thể dùng cho việc mã hóa (encryption), Khóa còn lại dùng cho giải mã (đối với thuật toán RSA)

So sánh

- **Mã đối xứng**
  - Cùng thuật toán với cùng khóa được dùng cho việc mã hóa và giải mã
  - Sender và Receiver phải cùng chia sẻ thuật toán và khóa
  - Khóa phải giữ bí mật
  - Không thể hoặc ít nhất không thực thế để giải mã một thống điệp nếu những thông tin khác có sẵn.
  - Sự hiểu biết về thuật toán cộng với các mẫu ciphertext phải đủ thì mới xác định ra được khóa.

- **Mã bất đối xứng**
  - Một thuật toán được dùng để mã hóa và giải mã với một cặp khóa, một khóa dành cho mã hóa và một dành do giải mã
  - Sender và receiver phải có một trong cặp khóa (không giống nhau)
  - Một trong hai khóa phải được giữ bí mật
  - Không thể hoặc ít nhất không thực thế để giải mã một thống điệp nếu những thông tin khác có sẵn.
  - Sự hiểu biết về thuật toán + một trong hai khóa + các mẫu ciphertext phải đủ thì mới có thể xác định được khóa còn lại.

Public-Key Application

- Có thể phân thành 3 loại:
  - **Mã hóa/giải mã (*Encryption/decryption*):** Sender mã hóa thông điệp bằng khóa public key của người nhận.
  - **Chữ ký số (*Digital signatures*)** – cung cấp chứng thực (authentication): Sender mã hóa thông điệp bằng khóa public key của người nhận. Chữ ký được lưu bằng một thuật toán áp đặt vào message hoặc gắn vào một khối nhỏ dữ liệu mà là một hàm của message
  - **Trao đổi khóa (*Key exchange*)**: Hai bên hợp tác để trao đổi **khóa phiên (session key)**

Public-Key Application

- Một vài thuật toán thì phù hợp cho tất cả các ứng dụng, loại khác thì chỉ dành riêng cho một loại ứng dụng

Algorithm	Encryption/Decryption	Digital Signature	Key Exchange
RSA	Yes	Yes	Yes
Elliptic Curve	Yes	Yes	Yes
Diffie-Hellman	No	No	Yes
DSS	No	Yes	No

Phá mã Public-key

- Tấn công vét cạn (Brute Force attack): Luôn luôn là có thể về mặt lý thuyết
  - → Sử dụng khóa đủ lớn (>512 bits)
  - → khóa lớn ảnh hưởng đến tốc độ của việc mã hóa và giải mã
- Tìm Private key khi biết Public key:
  - →Chưa được chứng minh tính khả thi của phương pháp này

An ninh Public-Key Cryptosystems

- An toàn của hệ mã hóa khóa công khai dựa trên độ khó của việc giải bài toán ngược.
- Tính bền của sự an toàn này còn phụ thuộc vào phương pháp tấn công của các thám mã

Ưu điểm mã hóa khóa công khai

- Đơn giản trong việc lưu chuyển khóa: Chỉ cần đăng ký một khóa công khai → mọi người sẽ lấy khóa này để trao đổi thông tin với người đăng ký → không cần thêm kênh bí mật truyền khóa.
- Mỗi người chỉ cần một cặp khóa (PR, KU) là có thể trao đổi thông tin với tất cả mọi người.
- Là tiền đề cho sự ra đời của chữ ký số và các phương pháp chứng thực điện tử.

Hạn chế của mã Public keys

- Tốc độ xử lý
  - Các giải thuật khóa công khai chủ yếu dùng các phép nhân chậm hơn nhiều so với các giải thuật đối xứng
  - Không thích hợp cho mã hóa thông thường
  - Thường dùng trao đổi khóa bí mật đầu phiên truyền tin
- Tính xác thực của khóa công khai
  - Bất cứ ai cũng có thể tạo ra một khóa công khai
  - Chừng nào việc giả mạo chưa bị phát hiện có thể đọc được nội dung các thông báo gửi cho người kia
  - Cần đảm bảo những người đăng ký khóa là đáng tin

THANKS YOU